Lab 7.3 : Abuse/Control Contract และ Risk Handoff

ผลงานผู้เรียน • 18 ตุลาคม 2026 • **Design proposal : ยังไม่ implement/รัน probes**

ใช้ source-adr.md, source-dfd.md, source-contract.md, source-control-result.md และ source-diagram.svg เป็นหลักฐานเดิม; สายส่งมอบคือ ADR7.1 → DFD7.2 → Control7.3 ส่ง VoucherControlContract.md เป็น normative proposal สำหรับ case V-001 เดิม คง architecture/ownership แต่มี refinement ของ expiry bookkeeping ตามเกณฑ์ปัจจุบัน. HTML ฉบับเต็ม รวม contract และผลตรวจนี้ให้อ่านต่อเนื่อง.

เนื้อหางาน	ผลงานและหลักฐานเชิงเอกสาร
Abuse และ once-only	Contract §1–3: P1 state, P2 time, P3 replay, P4 atomic N≤1, P5 authority; probes เดิม positive/unknown/replay/state/cancel/expiry/race ครบ fixture scope; target extensions แยกนอก W8
Risk rank/response/owner/residual	Contract §4: T2=9 rank 1, T1=6 rank 2 พร้อมเกณฑ์/เหตุผลและเจ้าของ; mitigate ทั้งคู่ ยังไม่ถือว่ารับ residual หรือผ่าน control
Traceability และ W8	Contract §2–5 เชื่อม T1/T2 ↔ F2–F9 ↔ C1–C3 ↔ P1–P5 ↔ probes เดิม; ส่ง DFD+contract ให้ W8 refine จาก actual probes
Scope / evidence	คง ADR-VOUCHER-0001 และ writer เดียว; W8 เป็น single-process in-memory; HTTP/auth/DB/distributed requirements เป็น untested gaps ไม่อ้าง Team Notes/BOLA/noSonar หรือผลรันที่ไม่มี

ตามการตรวจ baseline ที่เอกสารเดิมบันทึกไว้ (รอบนี้ไม่ได้เปิด baseline): fixture same-voucher repeat ต้อง reject/already_used แม้ actor เดิม, ไม่มี receipt/event ใหม่; positive ต้องสำเร็จ และ race ต้องมี observation ครบก่อนตัดสิน. actor เป็น caller label ไม่ใช่ auth; ไม่มี requestId/roles/tenant/CommandResult/outbox/fault injection. Future target same-key transport REPLAY ยังเป็น design proposal แยกจาก fixture oracle; ไม่บังคับเพิ่มโปรแกรมหรือ probes. Review นี้เป็น document consistency review ไม่ใช่ owner approval หรือผลรัน.

Risk ledger อยู่ใน Contract §4: T2 rank 1 (9), T1 rank 2 (6); response=mitigate, accountable=Voucher domain team ทั้งคู่; residual ยังเปิดและไม่ลดคะแนนก่อนมีหลักฐาน. Handoff W8 ใช้ Contract §3/§5 และ DFD7.2 โดยไม่เพิ่มโจทย์หรือ probes.

Risk ledger จาก DFD7.2

เกณฑ์ inherent risk ที่เสนอ: Impact 1=เล็กน้อย, 2=ข้อมูล/งานต้อง reconcile, 3=consume/สิทธิ์หรือมูลค่าเสียหาย; Likelihood 1=ต้อง privileged bypass, 2=ต้องมี defect/เงื่อนไขเฉพาะ, 3=retry/concurrency ปกติก็กระตุ้นได้เมื่อ control ขาด. Score=I×L เป็น ordinal triage ไม่ใช่ความน่าจะเป็นที่วัด. Residual ยังไม่ลดคะแนนจนมีหลักฐาน.

Rank / threat / score	Rationale / response / owner	Residual และ evidence gate
1 T2 / I3×L3=9; F4–F9; P3/P4/P5	Race และ lost response เกิดได้ในงานปกติ; duplicate consume/partial commit กระทบ integrity สูง. **Mitigate** ด้วย C2+C3 ก่อน release. Accountable: Voucher domain team; Platform ร่วม DB proof; consumer team รับ dedup	W8 ผ่านก็ยังไม่พิสูจน์ shared DB/multi-process/crash หรือ external effects. ต้องมี DB concurrency/rollback/restart และ duplicate-delivery probes ก่อน owner พิจารณารับ residual; ไม่มี risk acceptance แล้ว

Rank / threat / score	Rationale / response / owner	Residual และ evidence gate
2 T1 / I3×L2= 6; F2–F6; P1/P2/P5	Unauthorized/expired consume impact สูงเท่ากัน แต่ต้องมี validation/policy/writer bypass defect; likelihood เป็นสมมติฐาน. **Mitigate** C1+C2. Accountable: Voucher domain team; Identity ดูแล auth, Platform writer credentials	Fixture ตรวจได้เฉพาะ state/time branches; actor ไม่ใช่ authentication และไม่มี authorization branch; session forgery, CSRF, actual clock/lock และ alternate DB writers ยังเปิด. ต้อง review identity source + HTTP negative/positive + DB access evidence; หากพบ bypass ให้ยกระดับ rank ทันที

VoucherControlContract : Lab 7.3

ผลงานผู้เรียน • 18 ตุลาคม 2026 • **Target controls เป็น design proposal; fixture scope ตรวจจาก source; probes ทั้งหมด not run**

1. Scope และ vocabulary

Control7.3 ปรับ refinement ของ expiry oracle จาก ADR7.1 เดิม: ADR เดิมเป็นหลักฐานการออกแบบตามเวลานั้น; เกณฑ์ปัจจุบันกำหนดให้ active ที่ now>=expires_at ต้อง reject แต่ยอมคง active หรือเปลี่ยนเป็น expired เพื่อ bookkeeping โดยไม่มี receipt/redemption/event ใหม่ และ counts=0.

รับ ADR7.1 → DFD7.2/threats → Control7.3 (เอกสารนี้); diagram.svg. ไม่มี dependency ต่อ Data/API Contract แยก; flow/ownership ที่จำเป็นอยู่ใน DFD7.2 §2 และ controls อยู่ที่นี่. คง modular monolith: VoucherService ภายใน VoucherModule เป็น writer เดียว; worker ใน backend เดียว; target shared DB แยก container. Voucher team เป็น domain owner, Identity team ดูแล trusted identity, Platform ดูแล DB infrastructure, consumer team ดูแล downstream dedup.

V-001 เริ่ม ISSUED; issuer=ISS-01, beneficiary=U-101, OP-01 เป็น operator ของ ISS-01; clock เริ่ม 2026-10-18T00:00:00Z; expiry=2026-10-20T00:00:00Z. R-A/R-B เป็นชื่อย่อ UUID เฉพาะ future target policy ไม่ใช่ fixture inputs. W8 ใช้ codes/actor/integer clock ตาม §3 และสร้าง service ใหม่ในแต่ละ probe.

N=จำนวน committed Redemption ของ voucher; E=จำนวน logical VoucherRedeemed ไม่รวม Activated/Cancelled และไม่ใช่ delivery count. K=(actorId,voucherId,action,requestId); fp=normalized payload fingerprint รวม clientReference. A=trusted subject ตรง beneficiary + beneficiary role + stored issuer membership; operator ไม่มีสิทธิ์ redeem แทน. ต้อง authorize ก่อนดู state หรือคืน replay.

2. Target predicates และ enforcement : design proposal

ID / link	Requirement : design proposal
P1 State / T1 / F4–F6 / C2	New consume ต้อง state=ACTIVE. ISSUED→ACTIVE ผ่าน activate; ISSUED/ACTIVE→CANCELLED ผ่าน authorized cancel; ACTIVE→REDEEMED ผ่าน redeem. REDEEMED/CANCELLED terminal ไม่มี reset. Activate จาก ACTIVE ได้ ALREADY_ACTIVE, cancel ซ้ำได้ ALREADY_CANCELLED โดยไม่เพิ่ม event
P2 Time / T1 / F5 / C2	New transition ต้อง serverNow<expiresAt โดยอ่าน UTC หลังได้ lock; now=expiry ก็ EXPIRED. EXPIRED เป็น derived condition ไม่รอ job. REDEEMED history ไม่เปลี่ยนตามเวลา; committed replay เป็นข้อยกเว้นที่ไม่ consume ใหม่
P3 Target transport replay / T2 / F4–F9 / C3+C2	Re-authorize แล้ว lookup K ก่อน state/time: committed K+fp เดิม → REPLAY พร้อม receipt เดิม; K เดิมแต่ fp ต่าง → IDEMPOTENCY_CONFLICT. Key ใหม่หลัง redeem → ALREADY_REDEEMED. Replay หลัง expiry ใช้ได้เมื่อยัง authorized; เก็บ successful mapping ตลอดอายุ record/archive ที่ lookup ได้

ID / link	Requirement : design proposal
P4 Atomic / T2 / F5–F8 / C2	N≤1 เสมอ; redeem commit เพิ่ม state/version, Redemption, successful CommandResult, outbox พร้อมกัน. สำหรับ redemption ที่สำเร็จ N=E=1 และ state=REDEEMED; failure ก่อน commit ไม่เปลี่ยนทั้งชุด. ใช้ shared DB transaction + row lock ทุก action + UNIQUE(voucherId) + unique K + logical event uniqueness. Commit เป็น linearization point; ตอบ success หลัง commit
P5 Authority / T1,T2 / F2–F6 / C1	New consume iff A ∧ ACTIVE ∧ now<expiry ภายใน atomic boundary. ตรวจ session/CSRF/schema ที่ adapter, สร้าง trusted ActorContext; module เทียบ stored data ก่อน replay. ไม่รับ owner/state/time จาก body; จำกัด DB writer. ตรวจ actor ใหม่ทุก request

ลำดับข้างต้นเป็น future target: adapter → lock → authorize → lookup K → state/time → commit → response. Target อาจตอบ REPLAY สำหรับคำขอ transport เดิมโดยไม่ consume ใหม่ แต่ **fixture P3 ต้อง reject การ redeem voucher เดิมทุก actor แม้ actor เดิม**. ไม่ใช้ K/fp/receipt replay มาเปลี่ยน oracle ของ lab; รายละเอียด target error precedence ไม่ใช่งานเพิ่มให้ W8.

C1=trusted actor/scoped policy; C2=atomic consume/durable outbox; C3=bounded retry/stable receipt ตาม DFD7.2 §2 และ contract นี้. C3 เสนอ lock timeout 2s, deadline 5s, retry key เดิม ≤3 ครั้ง/burst พร้อม backoff+jitter แล้วตรวจภายหลัง; ค่าเหล่านี้ยังต้องวัด. Deadline request ต่างจาก voucher expiry: timeout/connection loss อาจ commit แล้ว จึงถือ outcome unknown ห้ามสร้าง key ใหม่อัตโนมัติหรืออ้าง rollback. Worker ส่ง committed outbox at-least-once; consumer dedup eventId; oldest pending>60s เสนอ alert ไม่ใช่ SLA ที่วัดแล้ว.

3. W8 abuse/controls : source-confirmed API, expected/not run

ข้อมูล baseline ในหัวข้อนี้อ้างตาม source-adr.md/source-contract.md ซึ่งบันทึกการอ่าน source เดิม; รอบนี้ไม่ได้เปิด baseline หรือรัน fixture. API ที่หลักฐานเดิมระบุคือ `redeem(code, actor, now, checkpoint=None)` → `Redemption(ok, reason, receipt_id, actor)`; `issue(code, expires_at)`, `activate(code)/cancel(code)` คืน bool; `snapshot(code)`, `events()`. Record ใช้ code/expires_at/state/redeemed_by; states issued/active/cancelled/expired/used. snapshot เพิ่ม redemption_count; events เป็น code/actor/receipt_id ไม่มี type หรือ outbox. actor=alice/bob เป็น caller label ไม่ใช่ authentication/role/tenant; now เป็น trusted integer NOW=10, EXPIRES_AT=100.

Fixture predicates: **P1** redeem เฉพาะ active; **P2** now<expires_at; **P3** used ต้อง reject รวม actor เดิม; **P4** atomic check-and-transition ทำให้ success/event ไม่เกินหนึ่ง; **P5** auth ไม่มีใน fixture เป็น target-only. C2 ส่วน state/time/atomic ใช้ตรวจใน memory ได้; C1 และ C3 transport retry ไม่มี fixture proof.

Baseline source ไม่ guard state/time ครบ, ยกเว้น same-actor used และแยก check/commit lock; เป็น static evidence ไม่ใช่ผลรัน. reasons ที่พบจริงคือ redeemed/unknown_voucher/already_used; ไม่ตั้งชื่อ reason ของ state/expiry ที่ยังไม่ได้ implement. Reject ต้อง ok=False ไม่มี receipt/redemption/event ใหม่; กรณี deny อื่นคง snapshot เดิม; เฉพาะ expiry ยอมเปลี่ยน state จาก active เป็น expired เพื่อ bookkeeping โดยไม่มี redemption effects และห้ามเพิ่ม event.

Probe เดิม / threat / predicates	Negative/abuse → expected	Positive control / observable
positive / T1 / P1,P2	ไม่ถือ reject ทุกคำสั่งว่าปลอดภัย	V-POSITIVE: activate=True; alice ที่ 10 → ok=True/redeemed, receipt_id ไม่ว่าง; used/redeemed_by=alice, redemption_count=event_count=1
unknown / lookup	V-MISSING → ok=False/unknown_voucher, ไม่มี event	positive เป็น known code ที่สำเร็จ
replay / T2 / P3,P4	V-REPLAY: second alice ที่ 11 → ok=False/already_used; snapshot คงเดิม, event_count=1	first สำเร็จหนึ่งครั้ง; ไม่คืน REPLAY success และไม่สร้าง receipt ใหม่

Probe เดิม / threat / predicates	Negative/abuse → expected	Positive control / observable
state / T1 / P1	V-STATE แยก issued/expired → reject, state คงเดิม, counts=0	positive เริ่ม issued แล้ว activate ก่อน consume
cancel / T1 / P1	V-CANCELLED: cancel=True แล้ว redeem reject; cancelled คงเดิม, counts=0	positive ไม่ cancel แล้ว consume ได้
expiry / T1 / P2	V-STATE active ที่ now>=expires_at (รวม now=100) → reject; state ยัง active หรือเปลี่ยนเป็น expired เพื่อ bookkeeping ได้; ไม่มี receipt/redemption/event ใหม่ และ counts=0	positive now=10<100 สำเร็จ
race / T2 / P4	V-RACE alice/bob: หนึ่ง success, loser ok=False/already_used; event_count=1	checkpoint_calls=2, errors=[], observations ครบ; used/redeemed_by/receipt ตรง winner

Lock ใน store ร่วมทั้ง service ไม่ใช่ per-voucher lock. Race ใช้ threads สองตัวใน child process ที่แยกเพื่อจำกัดเวลาสังเกต ไม่ใช่ distributed store. คง checkpoint scheduling seam; timeout/error/observation ไม่ครบคือ inconclusive ไม่ใช่ pass. probes.py เป็น observation ไม่ใช่ security verdict แม้ exit 0.

HTTP/session, issuer permission, idempotency, fault injection, cancel race, DB rollback/restart และ duplicate delivery เป็น future target verification นอก W8. ไม่มีข้อกำหนดเพิ่มโปรแกรมหรือ W8-01–08 ใหม่; ใช้เจ็ด probe names เดิมเท่านั้น.

4. Risk ledger และ decision

เกณฑ์ inherent risk ที่เสนอ: Impact 1=เล็กน้อย, 2=ข้อมูล/งานต้อง reconcile, 3=consume/สิทธิ์หรือมูลค่าเสียหาย; Likelihood 1=ต้อง privileged bypass, 2=ต้องมี defect/เงื่อนไขเฉพาะ, 3=retry/concurrency ปกติก็กระตุ้นได้เมื่อ control ขาด. Score=I×L เป็น ordinal triage ไม่ใช่ความน่าจะเป็นที่วัด. Residual ยังไม่ลดคะแนนจนมีหลักฐาน.

Rank / threat / score	Rationale / response / owner	Residual และ evidence gate
1 T2 / I3×L3= 9; F4–F9; P3/P4/P5	Race และ lost response เกิดได้ในงานปกติ; duplicate consume/partial commit กระทบ integrity สูง. **Mitigate** ด้วย C2+C3 ก่อน release. Accountable: Voucher domain team; Platform ร่วม DB proof; consumer team รับ dedup	W8 ผ่านก็ยังไม่พิสูจน์ shared DB/multi-process/crash หรือ external effects. ต้องมี DB concurrency/rollback/restart และ duplicate-delivery probes ก่อน owner พิจารณารับ residual; ไม่มี risk acceptance แล้ว
2 T1 / I3×L2= 6; F2–F6; P1/P2/P5	Unauthorized/expired consume impact สูงเท่ากัน แต่ต้องมี validation/policy/writer bypass defect; likelihood เป็นสมมติฐาน. **Mitigate** C1+C2. Accountable: Voucher domain team; Identity ดูแล auth, Platform writer credentials	Fixture ตรวจได้เฉพาะ state/time branches; actor ไม่ใช่ authentication และไม่มี authorization branch; session forgery, CSRF, actual clock/lock และ alternate DB writers ยังเปิด. ต้อง review identity source + HTTP negative/positive + DB access evidence; หากพบ bypass ให้ยกระดับ rank ทันที

5. W8 handoff และหลักฐานที่ต้องส่งกลับ

ส่ง VoucherDFD, threat table DFD7.2, contract นี้ และ risk decision. เชื่อม T1→state/cancel/expiry, T2→replay/race, positive เป็น control และ unknown เป็น lookup boundary. คง T1/T2, F1–F9, C1–C3, P1–P5 โดยแยก target-only predicates ชัดเจน; F1–F9 ไม่ใช่ชื่อ API ที่ fixture implement.

W8 ใช้ baseline single-process in-memory service ตาม §3; ไม่มี CommandResult/requestId/roles/tenant/outbox/draft fault injection และไม่มี HTTP/auth/DB/durability/distributed proof. ไม่บังคับเพิ่ม setup หรือ probes. Target transport REPLAY เป็น future policy เท่านั้น; lab contract ยังคง reject repeated consume.

หลักฐาน W8 ที่ยังไม่มีคือ outcomes/receipt, snapshot (state/redeemed_by/redemption_count), event_count/events และ race checkpoint_calls/errors/success_count. Fixture ไม่มี version, successful K หรือ Activated/Cancelled event types. Gaps ยังเปิดต่อ owner; รอบนี้ไม่มีผลรันหรือ exploit proof.